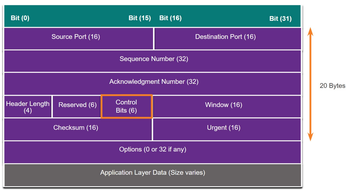
TCP and UDP Vulnerabilities

3.7.1

TCP Segment Header

While some attacks target IP, this topic discusses attacks that target TCP and UDP.

TCP segment information appears immediately after the IP header. The fields of the TCP segment and the flags for the Control Bits field are displayed in the figure.



The following are the six control bits of the TCP segment:

- **URG** - Urgent pointer field significant
- **ACK** - Acknowledgment field significant
- **PSH** - Push function
- **RST** - Reset the connection
- **SYN** - Synchronize sequence numbers
- **FIN** - No more data from sender

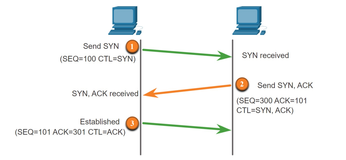
3.7.2

TCP Services

TCP provides these services:

- **Reliable delivery** - TCP incorporates acknowledgments to guarantee delivery. Instead of relying on upper-layer protocols to detect and resolve errors, if a timely acknowledgment is not received, the sender retransmits the data. Requiring acknowledgments of received data can cause substantial delays. Examples of application layer protocols that make use of TCP reliability include HTTP, SSL/TLS, FTP, DNS zone transfers, and others.
- **Flow control** - TCP implements flow control to address this issue. Rather than acknowledge one segment at a time, multiple segments can be acknowledged with a single acknowledgment segment.
- **Stateful communication** - TCP stateful communication between two parties occurs during the TCP three-way handshake. Before data can be transferred using TCP, a three-way handshake opens the TCP connection, as shown in the figure. If both sides agree to the TCP connection, data can be sent and received by both parties using TCP.

TCP Three-Way Handshake



A TCP connection is established in three steps:

1. The initiating client requests a client-to-server communication session with the server.
2. The server acknowledges the client-to-server communication session and requests a server-to-client communication session.
3. The initiating client acknowledges the server-to-client communication session.

3.7.3

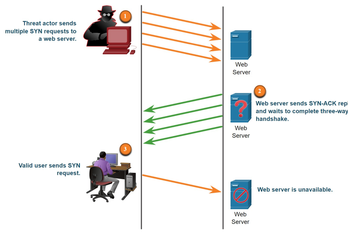
TCP Attacks

Network applications use TCP or UDP ports. Threat actors conduct port scans of target devices to discover which services they offer.

TCP SYN Flood Attack

The TCP SYN Flood attack exploits the TCP three-way handshake. The figure shows a threat actor continually sending TCP SYN session request packets with a randomly spoofed source IP address to a target. The target device replies with a TCP SYN-ACK packet to the spoofed IP address and waits for a TCP ACK packet. Those responses never arrive. Eventually the target host is overwhelmed with half-open TCP connections, and TCP services are denied to legitimate users.

TCP SYN Flood Attack



1. The threat actor sends multiple SYN requests to a web server.
2. The web server replies with SYN-ACKs for each SYN request and waits to complete the three-way handshake. The threat actor does not respond to the SYN-ACKs.
3. A valid user cannot access the web server because the web server has too many half-opened TCP connections.

TCP Reset Attack

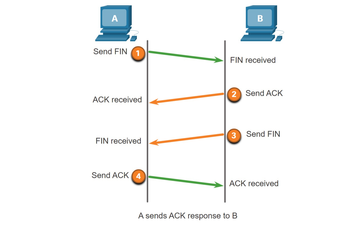
A TCP reset attack can be used to terminate TCP communications between two hosts. TCP can terminate a connection in a civilized (i.e., normal) manner and uncivilized (i.e., abrupt) manner.

The figure displays the civilized manner when TCP uses a four-way exchange consisting of a pair of FIN and ACK segments from each TCP endpoint to close the TCP connection.

The uncivilized manner is when a host receives an TCP segment with the RST bit set. This is an abrupt way to tear down the TCP connection and inform the receiving host to immediately stop using the TCP connection.

A threat actor could do a TCP reset attack and send a spoofed packet containing a TCP RST to one or both endpoints.

Terminating a TCP Connection



Terminating a TCP session uses the following four-way exchange process:

1. When the client has no more data to send in the stream, it sends a segment with the FIN flag set.
2. The server sends an ACK to acknowledge the receipt of the FIN to terminate the session from client to server.
3. The server sends a FIN to the client to terminate the server-to-client session.
4. The client responds with an ACK to acknowledge the FIN from the server.

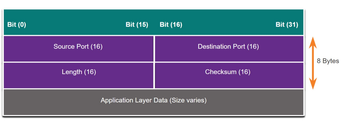
TCP Session Hijacking

TCP session hijacking is another TCP vulnerability. Although difficult to conduct, a threat actor takes over an already-authenticated host as it communicates with the target. The threat actor must spoof the IP address of one host, predict the next sequence number, and send an ACK to the other host. If successful, the threat actor could send, but not receive, data from the target device.

3.7.4

UDP Segment Header and Operation

UDP is commonly used by DNS, TFTP, NFS, and SNMP. It is also used with real-time applications such as media streaming or VoIP. UDP is a connectionless transport layer protocol. It has much lower overhead than TCP because it is not connection-oriented and does not offer the sophisticated retransmission, sequencing, and flow control mechanisms that provide reliability. The UDP segment structure, shown in the figure, is much smaller than TCP's segment structure.



Although UPD is normally called unreliable, in contrast to TCP's reliability, this does not mean that applications that use UDP are always unreliable, nor does it mean that UDP is an inferior protocol. It means that these functions are not provided by the transport layer protocol and must be implemented elsewhere if required.

The low overhead of UDP makes it very desirable for protocols that make simple request and reply transactions. For example, using TCP for DHCP would introduce unnecessary network traffic. If no response is received, the device resends the request.

3.7.5

UDP Attacks

UDP is not protected by any encryption. You can add encryption to UDP, but it is not available by default. The lack of encryption means that anyone can see the traffic, change it, and send it on to its destination. Changing the data in the traffic will alter the 16-bit checksum, but the checksum is optional and is not always used. When the checksum is used, the threat actor can create a new checksum based on the new data payload, and then record it in the header as a new checksum. The destination device will find that the checksum matches the data without knowing that the data has been altered. This type of attack is not widely used.

UDP Flood Attacks

You are more likely to see a UDP flood attack. In a UDP flood attack, all the resources on a network are consumed. The threat actor must use a tool like UDP Unicorn or Low Orbit Ion Cannon. These tools send a flood of UDP packets, often from a spoofed host, to a server on the subnet. The program will sweep through all the known ports trying to find closed ports. This will cause the server to reply with an ICMP port unreachable message. Because there are many closed ports on the server, this creates a lot of traffic on the segment, which uses up most of the bandwidth. The result is very similar to a DoS attack.

3.7.6

Check Your Understanding - TCP and UDP Vulnerabilities

Check your understanding of TCP and UDP vulnerabilities by choosing the BEST answer to the following questions.

1. Which attack exploits the three-way handshake?
   - TCP reset attack
   - UDP flood attack
   - (•) TCP SYN Flood attack
   - DoS attack
   - TCP session hijacking

2. Two hosts have established a TCP connection and are exchanging data. A threat actor sends a TCP segment with the RST bit set to both hosts informing them to immediately stop using the TCP connection. Which attack is this?
   - (•) TCP reset attack
   - UDP flood attack
   - TCP SYN Flood attack
   - DoS attack
   - TCP session hijacking

3. Which attack is being used when the threat actor spoofs the IP address of one host, predicts the next sequence number, and sends an ACK to the other host?
   - TCP reset attack
   - UDP flood attack
   - TCP SYN Flood attack
   - DoS attack
   - (•) TCP session hijacking

4. A program sends a flood of UDP packets from a spoofed host to a server on the subnet sweeping through all the known UDP ports looking for closed ports. This will cause the server to reply with an ICMP port unreachable message. Which attack is this?
   - TCP reset attack
   - (•) UDP flood attack
   - TCP SYN Flood attack
   - DoS attack
   - TCP session hijacking

Check

Show Me

Reset